

## Table of Contents

**Estado de revisión:** Borrador de traducción asistida por máquina. Requiere revisión humana de terminología, significado, enlaces, formato y vigencia técnica antes de marcarse como edición final.

### Seguridad de la seguridad

#### Y COMPLIENCIA DE CLOUD

Manual de Gestor Práctica y Analista Junior

**TEN Lo que este manual hace:** Explica la gobernanza segura de la nube, arquitectura, identidad, redes, datos, cargas de trabajo, aplicaciones, Kubernetes, SaaS, monitoreo, resiliencia, pruebas de evidencia, CSA CCM v4.1, herramientas de código abierto, decisiones de gestión y trabajo analista orientado al trabajo. | |

**Alberto (Al) Leiva**

Primera edición • Julio 2026

## Prefacio

Los cambios de computación en la nube que opera la tecnología, la rapidez con que aparecen los recursos y dónde se cumplen las responsabilidades de seguridad. No elimina la rendición de cuentas. Un proveedor seguro todavía puede tener un inquilino de clientes inseguros, diseño de identidad, aplicación, flujo de datos, integración o configuración.

Este manual es neutral y utiliza lenguaje simple. No es asesoramiento legal, garantía o sustituto de la documentación del proveedor. Los servicios, características, amenazas, precios, contratos, regiones, estándares y guía de configuración cambian rápidamente. Confirme fuentes oficiales actuales y use cloud calificada, seguridad, privacidad, legal, arquitectura, ingeniería, auditoría y profesionales de negocios para decisiones reales.

**\*\* Nota de información actual:\*\*** Verificado 14 de julio de 2026. CSA Cloud Controls Matrix v4.1 es la última versión CCM/CAIQ, emitida en enero de 2026, con 207 objetivos de control en 17 dominios. Recursos actuales de CISA SCuBA, guía de nube NIST, CIS Se incorporan criterios de referencia y prácticas neutrales de proveedores. |

|.

### Cómo usar este manual

- Gerentes: comiencen con Capítulos 1–5, 17–25 y 27.
- Analistas juniors: estudiar en orden, completar los Capítulos 26 y 28–29, y utilizar las plantillas.

- Ingenieros en la nube: enfoque en los capítulos 4-16 y 19-20.
- GRC y evaluadores: enfoque en los capítulos 2-5 y 21-24.
- Adapte cada control y prueba al proveedor seleccionado, servicio, región, arquitectura, datos y responsabilidad del cliente.

## Tabla de contenidos

Este documento contiene una tabla de contenido de Word nativa y una guía de capítulo numerada por página permanente.

[Prefacio \[2\] \(#preface\)](#)

[Cómo utilizar este manual \[2\] \(#how-to-use-this-manual\)](#)

[Tabla de contenidos \[3\] \(#table-of-contents\)](#)

[Guía de cambio \[7\]\(#chapter-guide\)](#)

[1. Cloud Security Foundations \[8\]\(#cloud-security-foundations\)](#)

[1.1 NIST características esenciales \[8\]\(#nist-essential-characteristics\)](#)

[2. Modelos de servicio y responsabilidad compartida \[9\]\(#service-models-and-shared-responsibility\)](#)

[2.1 Matriz de responsabilidad \[9\]\(#responsibility-matrix\)](#)

[3. La gobernanza, la estrategia y el riesgo de las nubes \[10\]\(#cloud-governance-strategy-and-risk-appetite\)](#)

[3.1 Elementos del programa \[10\]\(#program-elements\)](#)

[4. Inventario, cuentas, suscripciones y propiedad \[11\]\(#inventory-accounts-subscriptions-and-ownership\)](#)

[4.1 Inventario \[11\]\(#inventory\)](#)

[4.2 Reconciliación \[11\]\(#reconciliation\)](#)

[5. Secure Architecture and Landing Zones \[12\]\(#secure-architecture-and-landing-zones\)](#)

[5.1 Principios de arquitectura \[12\]\(#architecture-principles\)](#)

[6. Identidad y acceso privilegiado \[13\]\(#identity-and-privileged-access\)](#)

[6.1 Identidad humana \[13\]\(#human-identity\)](#)

[6.2 Identidad de carga de trabajo \[13\]\(#workload-identity\)](#)

[7. Network and Connectivity Security \[14\]\(#network-and-connectivity-security\)](#)

7.1 Controles de red [14](#network-controls)

8. Seguridad de datos y privacidad [15](#data-security-and-privacy)

8.1 Controles de datos [15](#data-controls)

9. Encriptación, llaves, certificados y secretos [16](#encryption-keys-certificates-and-secrets)

9.1 Gestión clave [16](#key-management)

9.2 Secretos y certificados [16](#secrets-and-certificates)

10. Logging, Monitoring, and Detection [17](#logging-monitoring-and-detection)

10.1 Diseño de registro [17](#logging-design)

10.2 Limitaciones de pruebas [17](#evidence-limitations)

11. Vulnerability, Patch, and Exposure Management [18](#vulnerability-patch-and-exposure-management)

11.1 Gestión continua de la exposición [18](#continuous-exposure-management)

12. Compute, Storage, Database, and Endpoint Security [19](#compute-storage-database-and-endpoint-security)

13. Seguridad de la aplicación y DevSecOps [20](#application-security-and-devsecops)

13.1 Entrega segura [20](#secure-delivery)

14. Infraestructura como Código y Política como Código [21](#infrastructure-as-code-and-policy-as-code)

14.1 Controles de IaC [21](#iac-controls)

14.2 Política como código [21](#policy-as-code)

15. Containers and Kubernetes [22](#containers-and-kubernetes)

15.1 Controles de racimo [22](#cluster-controls)

16. Servicios sin servidores, API y servicios enviados por eventos [23](#serverless-apis-and-event-driven-services)

16.1 Controles sin servidor [23](#serverless-controls)

16.2 API security [23](#api-security)

17. SaaS Security and Business Applications [24](#saas-security-and-business-applications)

17.1 Reseña de SaaS [24](#saas-review)

18. Multi-Cloud, Hybrid Cloud y Portability [25](#multi-cloud-hybrid-cloud-and-portability)

18.1 Problemas comunes [25](#common-challenges)

18.2 Estrategia [25](#strategy)

19. Resiliencia, respaldo y recuperación de desastres [26](#resilience-backup-and-disaster-recovery)

19.1 Diseño de resiliencia [26](#resilience-design)

20. Respuesta de incidentes en la nube y forenses [27](#cloud-incident-response-and-forensics)

20.1 Prepare [27](#prepare)

20.2 Responder [27](#respond)

21. Privacy, Legal, Contract, and Data Residency [28](#privacy-legal-contract-and-data-residency)

21.1 Privacidad y revisión jurídica [28](#privacy-and-legal-review)

22. CSA Cloud Controls Matrix v4.1 Domains [29](#csa-cloud-controls-matrix-v4.1-domains)

22.1 Cómo utilizar CCM y CAIQ [29](#how-to-use-ccm-and-caiq)

23. Aseguramiento de la nube y evidencia del proveedor [30](#cloud-assurance-and-provider-evidence)

24. Evaluación, pruebas de evidencia y métricas [31](#assessment-evidence-testing-and-metrics)

24.1 Método de prueba [31](#test-method)

25. Servicios de IA y riesgos emergentes de la nube [32](#ai-services-and-emerging-cloud-risk)

25.1 Evaluación de la nube de IA [32](#ai-cloud-assessment)

26. Herramientas de código abierto [33](#open-source-tools)

26.1 Prowler [33](#prowler)

26.2 ScoutSuite [33](#scoutsuite)

26.3 Steampipe [34](#steampipe)

26.4 Custodio en la nube [34](#cloud-custodian)

26.5 Checkov [34](#checkov)

26.6 Trivy [34](#trivy)

26.7 tfsec [34](#tfsec)

26.8 Terrascan [35](#terrascan)

26.9 OpenTofu [35](#opentofu)

26.10 Agente de política abierta [35](#open-policy-agent)

26.11 Kyverno [35](#kyverno)

26.12 kube-bench [35](#kube-bench)

26.13 kube-hunter [36](#kube-hunter)

26.14 Falco [36](#falco)

26.15 Gitleaks [36](#gitleaks)

26.16 TruffleHog [36](#trufflehog)

26.17 Wazuh [37](#wazuh)

26.18 DefectDojo [37](#defectdojo)

27. Manual de seguridad en la nube para gerentes [38](#managers-cloud-security-playbook)

27.1 Ritmo operativo [38](#operating-rhythm)

28. Guía de la carrera de analista junior [39](#junior-analyst-career-guide)

28.1 Funciones comunes [39](#common-roles)

28.2 Trabajo típico [39](#typical-work)

29. Laboratorio Ficcional, Plan de Treinta Días y Preparación de Entrevistas [40](#fictional-laboratory-thirty-day-plan-and-interview-preparation)

29.1 Laboratorio de cartera [40](#portfolio-lab)

29.2 Plan de 30 días [40](#thirty-day-plan)

29.3 ¿Cuál es la responsabilidad compartida? [40](#what-is-shared-responsibility)

29.4 IaaS versus PaaS versus SaaS? [41](#iaas-versus-paas-versus-saas)

29.5 ¿Por qué la identidad es crítica en la nube? [41](#why-is-identity-critical-in-cloud)

29.6 ¿Qué es una zona de aterrizaje? [41](#what-is-a-landing-zone)

29.7 CSPM scan versus assessment? [41](#cspm-scan-versus-assessment)

29.8 ¿Qué es la infraestructura como código? [41](#what-is-infrastructure-as-code)

29.9 ¿Cómo aseguras secretos? [41](#how-do-you-secure-secrets)

29.10 ¿Cómo verifica la recuperación de la nube? [41](#how-do-you-verify-cloud-recovery)

29.11 ¿Qué es CSA CCM v4.1? [41](#what-is-csa-ccm-v4.1)

29.12 ¿Qué hace un buen analista junior? [41](#what-makes-a-good-junior-analyst)

30. Plantillas, Glosario, Índice y Referencias [42](#templates-glossary-index-and-references)

30.1 Registro de inventario y responsabilidad de la nube [42](#cloud-inventory-and-responsibility-record)

30.2 Papel de control de la nube [42](#cloud-control-workpaper)

30.3 Revisión de la garantía de los proveedores [42](#provider-assurance-review)

30.4 Registro de incidentes y recuperación [42](#incident-and-recovery-record)

30.5 Glosario [43](#glossary)

30.6 Índice de asunto [43](#subject-index)

30.7 Referencias oficiales [44](#official-references)

Guía del Capítulo

## Capítulo |

|... ——— La vida— | | 1 | Fundaciones de Seguridad en la Nube | 2 Modelos de Servicio Permanente y Responsabilidad Compartida | — 3 — La gobernanza, la estrategia y el riesgo en la nube | 4 | Inventario, Cuentas, Suscripciones y Propiedad TENED 8 | TEN 5 TENIDOS Zonas seguras de Arquitectura y Aterrizaje | 6 Silenciosos Identidad y Acceso Privilegiado | | 7 | Red y Seguridad de la Conectividad | 8 | Seguridad y privacidad de los datos TEN 9 | Encriptación, Claves, Certificados y Secretos | 13 | TEN 10 TERRITORIFICACIÓN, Monitoreo y Detección — Vulnerabilidad, Patch, y Exhibición de la Expresión TEN 12 | Compute, Storage, Database, and Endpoint Security | 13 | Seguridad de la Aplicación y DevSecOps | 14 | Infraestructura como Código y Política como Código | 15 | Containers and Kubernetes | 19 TEN 16 TERRITORIOS sin servidor, API y servicios enviados por eventos | 17 | SaaS Security and Business Applications | 21 | | 18 — Multi-Cloud, nube híbrida y Portabilidad Silencioso 22 | |, Resiliencia y Recuperación de Desastres | | 20 | Cloud Incident Response and Forensics TEN 21 TENIDA Privacidad, Legal, Contrato y Residencia de Datos | 22 | CSA Cloud Controls Matrix v4.1 Domains TEN 27 | Silencioso 23 | en la Nube Assurance and Provider Evidence Silencioso 24 Evaluación, Pruebas de Evidencia y métricas tención 25 | AI Services and Emerging Cloud Risk tención 31 | | 26 | Open-Source Herramientas | 32 | Nube Cuaderno de Seguridad de la Nube Cuaderno de la Vida 37 | 28 | Junior Analyst Guía de Carreras | 29 | Fictional Laboratory, Treinta Días Plan, y Preparación de Entrevista | 30 TENIDOS Plantillas, Glosario, Índice y Referencias | 43 |

## 1. Cloud Security Foundations

*La seguridad de la nube protege rápidamente el cambio de tecnología compartida, identidades, datos, aplicaciones y servicios.*

### 1.1 NIST características esenciales

- Autoservicio bajo demanda: los consumidores pueden proporcionar recursos sin interacción manual del proveedor.
- Acceso amplio a la red: las capacidades están disponibles en redes mediante mecanismos estándar.

- Reunificación de recursos: los recursos de proveedores sirven a múltiples consumidores con independencia de ubicación a nivel de abstracción.
- La elasticidad rápida: los recursos pueden escalar rápidamente y pueden parecer ilimitados.
- Servicio de medición: el uso es monitoreado, controlado e informado.

## Implementación | Significado claro

|. | Ø Nube pública – Infraestructura de proveedores compartidos entre clientes con aislamiento lógico – Configuración de inquilinos, identidad, datos, aseguramiento de proveedores | Nube privada | Capacidad de la nube dedicada a una organización | Organización opera más responsabilidad de infraestructura TEN Comunidad nube | Compartido por organizaciones con necesidades comunes – Nube híbrida – Conectó distintos entornos de nube ANTERIED Identidad, datos, red, política, monitoreo, portabilidad

**TEN Cloud no es igual de seguro por defecto:** La velocidad, la automatización, los servicios gestionados y la infraestructura resiliente pueden mejorar la seguridad, pero los errores también escalan rápidamente. Gobernanza y guardias deben moverse a la velocidad de la nube.  
|. |

## 2. Modelos de servicio y responsabilidad compartida

*El proveedor y el cliente dividen la responsabilidad de manera diferente en IaaS, PaaS y SaaS.*

'img src="media/image1.png" style="width:6.15in;height:3.39605in" alt="Siempre confirman la documentación y el contrato de servicio exactos; los diagramas son puntos de partida simplificados".

Figura 1. Modelo de responsabilidad compartida

**Modelo** | \*\* Proveedor generalmente opera\*\* | **El cliente generalmente opera**

La vida eterna

---

————— TEN IaaS TENRI Instalaciones, hardware físico, virtualización básica e infraestructura de servicios TEN OS/workload, configuraciones, identidades, redes, aplicaciones, datos, monitoreo | PaaS | IaaS más componentes gestionados de tiempo de ejecución / plataformas – Aplicación, identidad, datos, configuración de servicio, integración, registro de archivos | SaaS | Plataforma de aplicación e infraestructura subyacente | Usuarios, roles, configuración de inquilinos, opciones de datos, integraciones, endpoints, monitorización TEN FaaS/serverless ANTE Infraestructura y ejecución gestionada plazo de ejecución TEN Código, dependencias, permisos, eventos, secretos, datos, configuración, observabilidad

### 2.1 Matriz de responsabilidad

- Por cada control, proveedor de nombres, cliente, porción compartida, fuente de pruebas, referencia contractual, evaluador, obligación de incidentes y responsabilidad de cambio/salida.

- Un informe del proveedor puede cubrir la infraestructura mientras el cliente debe probar la configuración y el uso del arrendatario.
- Gestionado no significa no propiedad; el cliente sigue eligiendo ajustes, identidades, datos, integraciones y riesgo aceptable.

### 3. Gobernanza de la nube, estrategia y competencia de riesgo

*Los conjuntos de glovernance permitieron el uso de la nube, propiedad, arquitectura, vigilancia, riesgo y escalada.*

### 3.1 Elementos del programa

- Estrategia, política, proveedores/servicios/regiones aprobados, usos prohibidos, reglas de datos y proceso de excepción.
- Centro cloud de excelencia o propiedad multifuncional equivalente a través de equipos de seguridad, plataforma, arquitectura, finanzas, privacidad, adquisiciones, legales y empresariales.
- jerarquía de cuentas/suscripción/proyectos, normas de la zona de aterrizaje, federación de identidad, modelo de red, registro, gestión clave, nombres y etiquetado y controles de base.
- El apetito por el riesgo y la intensificación obligatoria de la exposición pública, los datos confidenciales, el acceso privilegiado, los servicios no respaldados, la concentración y las restricciones legales.
- Proveedor de diligencia debida, contratos, registros de responsabilidad compartida, seguridad, vigilancia, coordinación de incidentes, portabilidad y salida.
- métricas, mejora continua, capacitación, coordinación de costos/seguridad y gestión de la deuda técnica.

### Rol

---

– Patrocinador ejecutivo

equipo de la plataforma de nube – Zonas de aterrizaje, servicios compartidos, vigilancias, operaciones | Propietario de Workload | propósito de negocios, datos, configuración, riesgo, recuperación, costo Requisitos, revisión de la arquitectura, monitoreo, evaluación, hallazgos | Equipo de identidad | Federación, MFA, privilegio, identidades de servicio, ciclo de vida | Privacidad / legal / adquisiciones | Funciones de datos, residencia, contrato, derechos, términos del proveedor | – FinOps | Visibilidad de los costos, propiedad, desperdicios, compromiso y riesgos tención Auditoría interna / evaluador

## 4. Inventario, cuentas, suscripciones y propiedad

*Los recursos de nube desconocidos no pueden ser gobernados, protegidos, supervisados o retirados.*



## 4.1 Inventario

- Organizaciones/tendientes, grupos de gestión/carpetas, cuentas/suscripciones/proyectos, regiones, propietarios de recursos, propósito empresarial, entornos y enlaces de facturación.
- Servicios, recursos, imágenes, contenedores, funciones, bases de datos, almacenamiento, redes, identidades, políticas, claves, secretos, certificados, dominios, registros, integraciones y proveedores.
- Categorías de datos, residencia, retención, exposición, encriptación, respaldo, recuperación y participación.
- Puntos finales públicos, caminos privilegiados, confianza cruzada, acceso de terceros, SaaS no gestionado y nube de sombras.
- Etiquetas/etiquetas para propietario, aplicación, medio ambiente, clase de datos, costo, crítica, nivel de recuperación, vencimiento y alcance de cumplimiento.

## 4.2 Reconciliación

- Compare APIs de proveedores de cloud con CMDB, repositorios IaC, identidad, DNS, red, adquisiciones, finanzas, vulnerabilidad y fuentes de monitoreo.
- Investigar los recursos huérfanos, sin etiquetar, desconocidos, duplicados, inactivos, no aprobados y expuestos públicamente.
- Automatizar el descubrimiento pero mantener la revisión responsable del propietario y pruebas de descomposición.

## 5. Zonas seguras de arquitectura y aterrizaje

*Las zonas de aterrizaje proporcionan bases reutilizables seguras antes de que llegue la carga de trabajo.*

Altura:3.39605in” alt=“Hierarquía, identidad, redes, registros centralizados, políticas y separación de carga de trabajo crean correderas consistentes.” / Propiedad

Figura 2. Base de la zona de aterrizaje

### 5.1 Principios de arquitectura

- Producción separada, no producción, seguridad, logging, networking, servicios compartidos y entornos de sandbox según riesgo.
- Centralizar la federación de identidad, el acceso de emergencia, la tala de auditoría, la vigilancia de la seguridad, el DNS, la conectividad, la política y las imágenes aprobadas cuando proceda.
- Utilizar políticas de denegación y salvaguardia para configuraciones peligrosas y controles preventivos para acciones de alto riesgo.

- Diseño de dominios, regiones/zonas, cuotas, capacidad, límites de servicio y recuperación de los requisitos de BIA.
- Documentar límites de confianza, vías administrativas, flujos de datos, servicios de proveedores, terceros y responsabilidades de clientes/providentes.
- Implementar la zona de aterrizaje y la configuración del volumen de trabajo mediante un código revisado controlado por la versión.

## Identidad y acceso privilegiado

*Los aviones de control de ruido hacen identidad, fichas, roles y directores de servicios activos críticos.*

Jim src="media/image3.png" style="width:6.15in;height:3.39605in" alt="Strong identity proofing, MFA, least privilege, session control, review, and revocation reduce control-plane risk." /

## Gráfico 3 Ciclo de vida de identidad en la nube

### 6.1 Human identity

- Federado a un proveedor de identidad autorizado; evite las identidades locales de nube no administradas excepto en emergencias controladas.
- Exigir un MFA resistente al phishing donde se justifique el riesgo, especialmente los administradores y acciones sensibles.
- Utilizar acceso basado en roles/atributos, privilegios justos a tiempo, aprobación, sesiones cortas e identidades de administración separadas.
- Control de cliente, contratista, soporte, vidrio, recuperación y acceso al proveedor.
- Derechos de revisión, cuentas inactivas, combinaciones tóxicas, confianza de cuenta cruzada y uso real.

### 6.2 Workload identity

- Preferir la identidad de carga de trabajo de corta duración y gestionar la identidad sobre claves estáticas incrustadas.
- Exigir permisos para exigir recursos/acciones y construir, desplegar, correr y apoyar identidades.
- Propietarios de inventario, propósito, credenciales, último uso, rotación, política de confianza y servicios dependientes.
- Detectar nuevos privilegios, federación, creación clave, consentimiento, impersonación y uso de token inusual.

## 7. Seguridad de la red y la conectividad

*Las redes de nube combinan constructos de proveedores, exposición a Internet, conectividad privada y controles de capas de aplicaciones.*

Controles de red

- Documentar redes virtuales, subnetes, enrutamiento, gateways, peering, endpoints privados, balanceadores de carga, firewalls, proxies, DNS, endpoints de servicio y enlaces on-premises.
- Negar por defecto cuando sea práctico; restringir las interfaces de gestión y utilizar las vías administrativas controladas.
- Segmento por confianza, medio ambiente, aplicación, datos y radio de explosión; prevenga el enrutamiento transitivo accidental.
- Usar protección de aplicaciones, controles DDoS, cortafuegos de aplicaciones web, portales API, restricciones de egreso y seguridad DNS según el riesgo.
- Encrypt traffic, validate certificates, protect private connectivity, and monitor flow/DNS/proxy/application records.
- Encontrar continuamente IPs públicas, reglas abiertas, grupos de seguridad permisivos, almacenamiento expuesto / bases de datos y túneles de sombra.

## 8. Seguridad de datos y privacidad

*La seguridad de los datos de voz comienza con propósito, ubicación, clasificación y minimización.*

'img src="media/image4.png" style="width:6.15in;height:3.39605in" alt="Track data from discovery and purpose through controlled deletion, including replicas, logs, backups, and subprocessors." /

Gráfico 4. Ciclo de vida de datos en la nube

### 8.1 Controles de datos

- Inventario de datos estructurados y no estructurados, objetos, bases de datos, instantáneas, análisis, registros, caches, índices, tiendas de inteligencia artificial, copias de seguridad, exportaciones y réplicas.
- Clasificar por sensibilidad, regulación, contrato, valor comercial y efecto sobre las personas.
- Minimizar la recogida, campos, retención, copias, ubicaciones, acceso, intercambio y uso de capacitación.

- Utilizar políticas de recursos, identidad, vías de red, encriptación, enmascaramiento/tokenización, DLP y monitoreo.
- Proteger metadatos y copias de seguridad; prevenir el acceso público y el intercambio entre los participantes y las cuentas a menos que se apruebe.
- Retención de pruebas, retención legal, exportación, corrección, eliminación, caducidad de respaldo y eliminación de proveedores/subprocesadores.

TEN **La residencia de datos es más que un selector de región:** Considere almacenamiento primario, réplicas, copias de seguridad, registros, soporte, subprocesadores, telemetría, recuperación en casos de desastre, administración y acceso legal del gobierno. |. |

## 9. Encriptación, llaves, certificados y secretos

*La Criptografía falla cuando las claves, secretos, certificados, algoritmos y permisos son mal gestionados.*

### 9.1 Gestión clave

- Definir opciones administradas por proveedores, gestionadas por clientes, proporcionadas por clientes o externamente por riesgo y obligación.
- Separar administración clave, uso clave, administración de la nube y auditoría en la práctica.
- Creación de control, importación, copia de seguridad, rotación, versión, desactivación, retraso de eliminación, recuperación, escrow y destrucción.
- Restrict key policies and cross-account grants; monitor every administrative and cryptographic use.
- Pérdida del plan, compromiso, falla de la región, salida del proveedor y restauración de respaldo cifrado.

### 9.2 Secretos y certificados

- Usar administradores secretos aprobados; nunca colocar secretos en fuente, imágenes, registros, entradas, chat, estado de IaC o archivos de usuario.
- Preferir credenciales de corta duración y rotación automática; propietario del inventario, propósito, alcance, último uso, expiración y dependencias.
- Automatizar la expedición/renovación de certificados con confianza controlada, proteger las llaves privadas, detectar la expiración y la creación de certificados no autorizados.

## 10. Registro, monitoreo y detección

*La evidencia en voz alta es útil cuando se permiten y revisan los eventos de control, plan de datos, volumen de trabajo, identidad y aplicación adecuados.*

### 10.1 Diseño de registro

- Definir los eventos necesarios antes del despliegue: actos administrativos, de identidad, políticas, acceso a datos, red, volumen de trabajo, aplicación, base de datos, clave, almacenamiento, seguridad, apoyo y eventos de proveedores.
- Permitir la cobertura a nivel de toda la organización y de toda la región; contabilizar nuevas cuentas/servicios y servicios que requieren ajustes separados de los eventos de datos.
- Centralizar a una cuenta de seguridad protegida, restringir la alteración o eliminación, utilizar la sincronización del tiempo y los controles de integridad, y mantener por riesgo/obligación.
- Normalizar la identidad, el recurso, la acción, resultado, fuente, ubicación, sesión, solicitud de identificación y tiempo sin perder evidencias primas.
- Supervisar la desactivación de registros, exclusiones, cambio de retención, nuevas acciones privilegiadas, exposición pública, eventos clave/secretos y acceso a datos anómalos.

#### Limitaciones de pruebas

- Los registros de proveedores pueden ser retrasados, muestreados, opcionales, extracostos, específicos para cada región o no disponibles después de una corta retención.
- La cifración limita la visibilidad del contenido de la red; la aplicación y el contexto de identidad se vuelven más importantes.
- Validar que las alertas crean casos investigados y acciones correctivas, no sólo dashboards.

## 11. Vulnerabilidad, manejo de parches y exposición

*La exposición al ruido cambia continuamente a través de configuración, código, imágenes, dependencias, identidades y servicios de proveedores.*

### 11.1 Gestión continua de la exposición

- Inventory internet-facing resources, attack paths, identities, software, imágenes, paquetes, APIs, almacenamiento, bases de datos, funciones y conexiones de terceros.
- Usar asesorías de proveedores, alimentación de vulnerabilidad, reglas de postura/configuración, escaneos de carga autenticados, escaneos de

imagen/dependencia, escaneos secretos y pruebas de penetración donde está autorizado.

- Priorizar la explotación, la capacidad de acceso a Internet, privilegios, datos sensibles, crítica empresarial, controles compensatorios y amenaza activa, no marcar solo.
- Patch or mitigate infrastructure, OS, runtime, application, container, function, dependency, appliance, and managed-service customer actions.
- Rastrear fallos responsables por los proveedores y avisos de servicio; verificar la configuración del cliente y las opciones de versión.
- Reprueba la corrección y mide la cobertura de la población, el tiempo, las excepciones y la recurrencia.

## 12. Compute, Storage, Database, and Endpoint Security

*Cada servicio gestionado elimina algunos trabajos operativos pero crea responsabilidades de configuración e integración.*

### Recurso

---

Ø Máquinas virtuales Ø Imágenes, parche, endurecimiento, EDR, discos, metadatos, ruta de administración ANTERI inventario, procedencia de imagen, config/scan, cobertura de agente  
tención de objetos

tención Gestionada base de datos

TEN Bloqueo / archivo de almacenamiento

Managed escritorio/punto de finalización ANTERIED Identidad, postura de dispositivo, aplicaciones, datos, sesiones, registro de entradas, políticas, acceso, eventos, pruebas de limpieza/terminación

— Imagen/servicio en el mercado

## 13. Seguridad de aplicaciones y DevSecOps

*Las aplicaciones de nube heredan el riesgo de diseño, código, dependencias, oleoductos, identidades, API y servicios gestionados.*

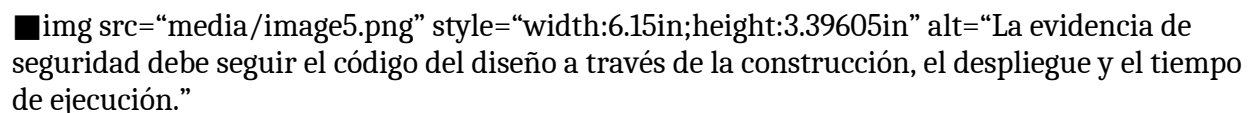
■  style="width:6.15in;height:3.39605in" alt="La evidencia de seguridad debe seguir el código del diseño a través de la construcción, el despliegue y el tiempo de ejecución." data-bbox="111 745 876 798"/>

Figura 5. Flujo de DevSecOps Cloud

### 13.1 Entrega segura

- Límites de confianza modelo de amenaza, datos, casos de abuso, identidad, aislamiento inquilino, dependencias de proveedores, resiliencia y comportamiento de fracaso.

- Usar revisión de código, dependencia/SBOM, secretos, SAST, IaC, contenedor, API, DAST, y pruebas manuales apropiadas para el riesgo.
- Proteger fuente, ramas, commits, corredores, sistemas de construcción, artefactos, registros, claves de firma, implementaciones y aprobaciones de producción.
- Utilizar la identidad de los oleoductos de corta duración, separación de deberes, entornos protegidos, procedencia firmada, artefactos inmutables y retroceso.
- Implementar la observabilidad, manejo seguro de errores, límites de velocidad, controles de entrada/salida y ganchos de incidentes.
- Rastrear vulnerabilidades y excepciones a la remediación verificada y la prueba.

## 14. Infraestructura como código y política como código

*La infraestructura y la política como código hacen que las decisiones de la nube sean repetibles, revisables, testables y escalables.*

### 14.1 IaC controls

- Utilizar módulos aprobados, versiones enmarcadas, registros de confianza, propiedad de códigos, revisión por pares, protección de ramas y versiones firmadas cuando corresponda.
- Código de escaneo y plan de configuración insegura, secretos, dependencias de riesgo, exposición pública, privilegio, encriptación, registro y resiliencia.
- Protege archivos estatales, salida del plan, credenciales, backends, bloqueos, información de deriva y registros CI.
- Exigir revisión y aprobación del plan antes de aplicar la producción; restringir los cambios de consola directa y detectar la deriva.
- Retroceso de pruebas, protección de eliminación, importación, migración y comportamiento de fracaso.

### 14.2 Policy as code

- Usar salvaguardias preventivas para estados prohibidos y políticas de detectives para condiciones que requieren investigación.
- Pruebas permitidas, denegadas, excepción, falta de datos y casos de cambio de servicio.
- Regla de la versión, propietario, racional, alcance, severidad, fecha efectiva, mapeo, excepción y retroceso.
- Nunca permita una remediación automatizada amplia sin revisión, aprobación, logging y recuperación de ondas secas.

## 15. Containers and Kubernetes

*Kubernetes distribuye responsabilidad en el plano de control de proveedores, configuración de grupos, nodos, imágenes, cargas de trabajo, red e identidad.*

“Managed Kubernetes todavía requiere el control de las cargas de trabajo, el acceso, las políticas, la red, los datos y la evidencia.” / Confeccionar

Figura 6. Capas de seguridad Kubernetes

### 15.1 Controles de racimo

- Grupos de inventario, versiones, propietarios, cargas de trabajo, espacios de nombres, nodos, registros, identidades, datos, ingresos y responsabilidad del proveedor.
- Acceso seguro API, federación, RBAC, cuentas de servicio, identidad de carga de trabajo, admisión, registros de auditoría y acceso de emergencia.
- Use imágenes mínimas de confianza firmadas, comprobaciones de vulnerabilidad/SBOM, ejecución no arraigada, sistemas de archivos solo lectura, capacidades caídas, límites de recursos y gestores secretos.
- Aplicar espacio de nombres y segmentación de redes, control de egresos, cifrado, protección de almacenamiento, respaldos, aplicación de políticas y detección de tiempo de ejecución.
- Patch soporta versiones de racimo/nodos y actualizaciones de pruebas, autoescalamiento, recuperación y compatibilidad de políticas.

## 16. Servidor, API y servicios de eventos

*Los sistemas ininterrumpidos y basados en eventos reducen la gestión de hosts pero aumentan las preocupaciones de identidad, evento, dependencia y observabilidad.*

### 16.1 Controles sin servidor

- Función de inventario, propietario, tiempo de ejecución, fuente, paquete de despliegue, dependencias, disparadores, destinos, papel, secretos, red, datos y retención.
- Utilizar un papel de ejecución menos privilegiado por propósito; prevenir los abusos controvertidos y cruzados.
- Validar y autenticar eventos, limitar la recursión/concurrencia, hacer cumplir los plazos/límites, y manejar mensajes venenosos y los registros de forma segura.
- Código de escaneo/dependencias/IaC, tiempo de ejecución de pins y capas, proteger el despliegue y eliminar funciones/versiones no utilizadas.
- Iniciar sesión, identidad, metadatos de eventos, error, destino y cambios administrativos al minimizar el contenido sensible.



## 16.2 API security

- Inventario de cada API/versión/ambiente y propietario; use gateways, autenticación, autorización, validación de esquemas, cuotas, límites de tarifas, TLS, errores seguros y registro.
- Prueba de autorización de objeto/función, validación de token, asignación masiva, inyección, SSRF, lógica comercial, inventario e integraciones de terceros.
- Proteger las teclas API y las teclas web, rotar secretos, firmar eventos y validar la resistencia de repetición.

## 17. SaaS Security and Business Applications

*La seguridad de SaaS depende en gran medida de la configuración, identidad, uso de datos, integraciones, puntos finales y evidencia de proveedores.*

### 17.1 Revisión de SaaS

- Propietario, propósito, usuarios, datos, ubicaciones, subprocesadores, uso de IA/entrenamiento, integraciones, crítica, recuperación, contrato, renovación y salida.
- SSO/MFA, roles, administradores, invitados, acceso de soporte, sesiones, compartir, colaboración externa, aplicaciones OAuth, fichas API y opiniones de acceso.
- Retención, eliminación, exportación, retención legal, encriptación, claves de cliente cuando esté disponible, DLP, etiquetas, registros de auditoría, alertas y e-descubrimiento.
- Proveedor SOC/ISO/CSA, alcance de seguridad, incidentes, prácticas de vulnerabilidad, continuidad, disponibilidad, subprocesadores y cambio de aviso.
- Base de referencia de configuración, controles continuos de deriva, consentimiento de aplicación arriesgado, intercambio de datos, usuarios inactivos y conciliación de licencias/cuentas.

**\*\* Lugar ciego:\*\*** La aprobación de las adquisiciones no es una operación segura. Revise la configuración de inquilinos, aplicaciones, roles, compartir, retener y cambiar el proveedor a lo largo de la relación. |

|. |

## 18. Multi-Cloud, Hybrid Cloud y Portability

*Multi-cloud y diseños híbridos pueden reducir o aumentar el riesgo dependiendo de la capacidad operacional real.*

## 18.1 Desafíos comunes

- Diferentes modelos de identidad, política, recurso, red, cifrado, registro, etiquetado, severidad, región y responsabilidad.
- Inventarios inconsistentes y herramientas de seguridad duplicadas que crean lagunas y alertan sobrecarga.
- Confianza cruzada, transferencia de datos, egresos, DNS, enrutamiento, certificados, secretos, tiempo y coordinación de incidentes.
- Proveedores y tecnologías compartidos que crean concentración oculta a pesar de múltiples nubes.
- Reclamaciones de portabilidad que fallan debido a servicios propietarios, volumen de datos, formatos, dependencias, habilidades, tiempo y coste.

## 18.2 Strategy

- Definir un estándar de control mínimo neutro del proveedor y mapearlo para la implementación/evidencia nativa del proveedor.
- Centralizar sólo lo que puede ser operado de forma fiable; preservar la profundidad de seguridad específica del proveedor.
- Prueba de fallo de identidad, pérdida de conectividad, fallo de región, salida de proveedores, exportación de datos, reconstrucción y salida.
- Usar la diversidad cuando reduce un fallo correlativo creíble y los equipos pueden operarlo con seguridad.

## 19. Resiliencia, respaldo y recuperación de desastres

*La resiliencia en voz alta requiere objetivos empresariales, arquitectura, datos de recuperación protegidos y restauración final a extremo probada.*

'img src="media/image7.png" style="width:6.15in;height:3.39605in" alt="Las características de disponibilidad de proveedores no prueban que el servicio completo del cliente puede reunirse con RTO y RPO." /

Gráfico 7. Resiliencia y recuperación en la nube

### 19.1 Diseño de resiliencia

- Realizar BIA; definir servicios críticos, productos mínimos, MTPD/MAO, RTO, RPO, dependencias, capacidad y criterios de aceptación.
- Select zones, regions, accounts, providers, failover, queues, retries, circuit breakers, Graceful degradation, capacity, and manual workarounds.
- Proteger copias de seguridad/snapshots/configuration/code/keys con separación, inmutabilidad o control offline, acceso segregación, retención y monitoreo.

- Orden de recuperación de documentos para identidad, networking, DNS, claves, datos, plataforma, aplicación, integraciones, monitoreo y usuarios.
- Realizar fallos realistas, corrupción, compromiso de identidad, ransomware, salida de proveedores y escenarios de dependencia de proveedores.

## 20. Respuesta de incidentes en la nube y forenses

*La respuesta a incidentes de ruido depende de pruebas de proveedores, identidad de plan de control, automatización segura y derechos compartidos.*

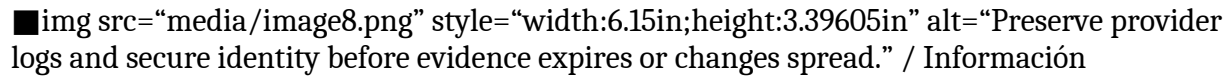
■  src="media/image8.png" style="width:6.15in;height:3.39605in" alt="Preserve provider logs and secure identity before evidence expires or changes spread." / Información

Gráfico 8 Flujo de trabajo de incidentes en la nube

### 20.1 Prepare

- Libros de juego, inventario de inquilinos/cuentas, diagramas, identidad y recuperación clave, contactos de proveedores, planes de soporte, contratos y acceso fuera de banda.
- Registros protegidos centrales con retención suficiente, métodos de recogida de proveedores/API, instantáneas, cuenta de evidencia, administración limpia y papeles entrenados.
- Aislamiento aprobado, revocación de token, restricción de políticas, rotación clave, cuarentena de red, instantánea de carga de trabajo y acciones de cierre de cuentas.

### 20.2 Respuesta

- Identidad, auditoría, API, red, datos, carga de trabajo, clave, almacenamiento, aplicación, facturación y evidencia de apoyo.
- Inquilino/cuenta/proyecto, región, identidad, papel, token, clave, recurso, datos, tiempo, automatización, integración y proveedor.
- Administración de confianza segura; revocar sesiones/tokens; eliminar funciones/apps/rules no autorizadas; rotar secretos en orden de dependencia.
- Restaurar del código de confianza/configuración/datos, validar la función de seguridad y negocio, reconectar en fases y monitorear la recurrencia.
- Coordinador, clientes, aseguradores, asesoría, autoridades y subprocesadores bajo obligaciones aprobadas.

## 21. Privacidad, Legal, Contrato y Residencia de Datos

*La privacidad y el cumplimiento en voz alta siguen los principios de procesamiento, responsabilidad, contrato, geografía y evidencia.*

## 21.1 Privacidad y revisión legal

- Identificar funciones, finalidad, autoridad o base jurídica, personas, datos, sensibilidad, derechos, retención, ubicación, transferencia y cuestiones relacionadas con el acceso público.
- Proveedor de mapas y todo subprocesador relevante, región de servicio, soporte, telemetría, respaldo, uso de IA y vía de eliminación.
- Contrato de seguridad, confidencialidad, limitación de propósitos, obligaciones de subprocesador, asistencia, aviso de incidentes, pruebas/audita, resiliencia, retorno/despido y cambio.
- Acceso a prueba, corrección, exportación, eliminación, retención, retención legal, comportamiento de respaldo, intercambio, consentimiento y controles de inquilinos.

| \*\* Silencioso\*\* | | SOC 2 | Proveedor sistema, criterios, período, pruebas, excepciones, CUECs, organizaciones de subservicio | El cliente debe implementar CUECs y controles de inquilinos | ISO/IEC 27001 latitud ISMS alcance, uso en la nube, proveedores, acceso, operaciones, incidentes, continuidad TENCION El alcance del certificado puede excluir un servicio o ubicación ANTE | TEN PCI DSS v4.0.1 | Alcance CDE, responsabilidad del proveedor de la nube, segmentación, evidencia, derechos de incidencias ANTE El cumplimiento del Proveedor no hace que el cliente cumpla | HIPAA Silencioso Socio de negocios, acuerdo, análisis de riesgos, salvaguardias, contingencia e incidentes | Aplicabilidad legal depende de hechos TENCION GDPR | Los términos del procesador, seguridad, transferencias, derechos, infracciones, eliminación, subprocesadores ANTERI Las funciones y los mecanismos de transferencia necesitan un análisis legal TEN NIST RMF/800-53 TENIDOS Asignación, implementación, evaluación, autorización, monitorización de TENA Tailor al servicio y los controles heredados TEN CSA CCM v4.1 | Objetivos de control específicos de la nube y la seguridad de CAIQ – Mapping no es el cumplimiento automático

## 22. CSA Cloud Controls Matrix v4.1 Dominios

*CSA CCM v4.1 organiza 207 objetivos de control de nubes en 17 dominios.*

### **Code / domain | Purpose**

| | Ø A destinatarioA — Auditoría " Garantía " , seguridad independiente e interna, planificación de evaluaciones, pruebas, conclusiones y coordinación de auditorías. | TEN AIS — Aplicación " Seguridad de la interfaz " , Diseño de aplicaciones seguras, API, desarrollo, pruebas, despliegue y protección de la interfaz. | TEN BCR — Gestión de la Continuidad Empresarial " Resilience Operacional " Continuidad, objetivos de recuperación, respaldos, ejercicios, dependencias y prestación de servicios resiliente. | TEN CCC — Control de Cambios " Gestión de Configuración | Bases de configuración aprobadas, cambios seguros, inventarios, pruebas, retroceso y control de deriva. – CEK — Cryptography, Encryption " Key Management – Cryptographic policy, keys, certificates, secrets, algoritmos, rotación, custodia y destrucción. | TEN DCS — Datacenter Security ANTE Instalaciones físicas, controles ambientales, equipos, medios de comunicación, acceso, monitoreo y eliminación. | DSP — Seguridad de datos "

Gestión de ciclos de vida ", inventario de datos, clasificación, minimización, uso, intercambio, retención, eliminación, privacidad y protección. | tención GRC — Gobernanza, Riesgo " Cumplimiento de la política permanente, rendición de cuentas, gestión de riesgos, obligaciones jurídicas, supervisión, presentación de informes y mejora. | tención de recursos humanos — Recursos humanos Silencioso Screening, acuerdos, concienciación, cambios de función, terminación, sanciones y responsabilidades laborales. | | IAM — Identidad " Gestión de Accesos ", vida útil, autenticación, autorización, privilegio, federación, identidades de servicio y revisión de acceso. | TEN IPY — Interoperabilidad " Portability " Normas, interfaces, exportación de datos, migración, transparencia de dependencia y capacidad de salida. | TEN IVS — Infraestructura " Virtualization Security ANTE Compute, redes, virtualización, contenedores, hosts, imágenes, segmentación y aislamiento de carga de trabajo. | TEN LOG — Monitorización de Logging, generación de eventos, reunión central, tiempo, protección, retención, detección, revisión y respuesta de alerta. | TEN SEF — Security Incident Management, E-Discovery & Cloud Forensics TEN Planes de incidentes, informes, pruebas, investigación, cooperación con proveedores, recuperación y aprendizaje. | TEN STA — Gestión de la Cadena de Suministros, Transparencia " Responsabilidad ", riesgo de proveedores y subproductores, contratos, propiedad, procedencia, vigilancia, incidentes y salida. tención TVM — Amenaza " Gestión de vulnerabilidades ". TEN UEM — Universal Endpoint Management | Gestión y protección de endpoints que acceden, administran o procesan servicios y datos en la nube. |

## 22.1 Cómo utilizar CCM y CAIQ

- Seleccione la fuente exacta CCM v4.1 y la versión de registro/fecha.
- Determinar proveedor, cliente o aplicabilidad compartida para cada objetivo de control relevante.
- Utilizar respuestas del proveedor de CAIQ como afirmaciones que requieren validación de pruebas basadas en el riesgo.
- Controles de mapa a arquitectura, propietario, implementación, evidencia, prueba, hallazgo y remediación.
- Use Directrices de Implementación y Auditoría en las que esté autorizado/disponible, a la vez que se adapte al servicio y al riesgo.
- No reclamar el nivel de CSA STAR o la certificación a menos que la entrada exacta del registro y el alcance lo apoyen.

## 23. Aseguramiento de la nube y evidencia del proveedor

*La garantía de la compañía reduce la incertidumbre sólo cuando el alcance y la responsabilidad del cliente coinciden con el uso real.*

**Artifact** Silencioso\*\* | . | | SOC 2 Tipo 2 | Entidad/servicio, criterios, período, opinión, pruebas, excepciones, CUECs, organizaciones de subservicio, eventos posteriores | ISO certificado Silencioso Organización, alcance de servicio/ubicación, versión estándar, organismo de certificación, acreditación, fechas, status | — CSA STAR / CAIQ ANTERIOR nivel del registro,

versión CCM/CAIQ, servicio exacto/entidad, respuestas, evidencia, fecha prueba de penetración Silencioso, fecha, semestre, metodología, exclusiones, hallazgos, corrección, retest | viv Arquitectura/responsabilidad | Proveedor/limitación de clientes, aislamiento de inquilinos, ruta de administración, datos, subprovidentes, control de propiedad – Resilience evidence tención Arquitectura, dependencias, RTO/RPO, ejercicios, resultados reales, fallos, corrección | TEN Vulnerability/development TEN Disclosure, secure SDLC, SBOM, scan/testing, patch targets, advisories, end-of-life | tención Contrato / SLA Silencioso Seguridad, privacidad, aviso, evidencia, disponibilidad, soporte, cambio, salida, remedios

**TEN Escalera de vídeo:** Un cuestionario es útil para el descubrimiento. Aumenta la confianza mediante documentos pertinentes, seguridad independiente, pruebas técnicas, observación, poblaciones completas y remediación verificada. | |.

## 24. Evaluación, pruebas de evidencia y métricas

*La evaluación de voz se une a criterios exactos, poblaciones API completas, evidencia confiable, juicio humano y retesting.*

“La prueba de configuración automatizada se convierte en garantía sólo después de que se evalúen el alcance, la confiabilidad, las excepciones y el riesgo”.

Figura 9. Cadena de prueba de pruebas en la nube

### 24.1 Método de prueba

- Definir los requisitos, proveedor/servicio, arrendatario/cuenta, región, tipos de recursos, período, datos, medio ambiente y asignación de clientes/productores.
- Determinar la población completa utilizando API autorizadas y reconciliarse con las fuentes independientes de inventario/billing/IaC/identity.
- Recopilar configuración, política, evento, proceso, contrato y evidencia humana con tiempo, fuente, versión, consulta, permisos y limitaciones.
- Diseño y operación de prueba; utilice automatización de población completa donde muestreo confiable y defensible cuando sea necesario.
- Validar permisos efectivos y controles heredados o compartidos, no sólo ajustes previstos.
- Escribir condición, población, riesgo, causa, acción, propietario, fecha, control provisional y retest.

Silencioso \*\* Métrico\*\* | ————— | Ø Recursos activos para propietarios válidos | Exposición pública | Recursos accesibles a Internet por estado aprobado/no aprobado y crítico | – MFA / cobertura de privilegios – Identidades privilegiadas con MFA / JIT requerido Ø Cobertura de registro – Cuentas/servicios En-scopios enviando registros requeridos ÷ cuentas/servicios en-scopios Ø Encryption/key compliance tención Requisitos de los recursos sensibles requeridos de la política clave – IaC coverage | Recursos de

producción gestionados por código aprobado | Buscar edad | Días abiertos por severidad, explotabilidad, exposición, propietario y excepción – Recuperación de la vida útil  
Representante prueba reunión completo RTO y RPO

## 25. Servicios de IA y riesgos emergentes de la nube

*Los servicios de Cloud AI añaden un modelo, datos, agente, plugin, cadena de proveedores y un riesgo de cambios rápido.*

### 25.1 Evaluación de la nube de IA

- Caso de uso aprobado, efecto de decisión, usuarios, usos prohibidos, supervisión humana y tratamiento de fallos esperados.
- Promptas, subidas, salidas, incrustaciones, índices, estudios finos, registros, retroalimentación, retención, eliminación, ubicación, transferencia y uso de entrenamiento.
- Modelo/providente/versión, alojamiento, identidad, permisos, herramientas/agentes/plugins, fuentes de datos, redes, secretos y subprocesadores.
- Inyección rápida, fuga de datos, uso indebido de herramientas, abuso de modelos, salida insegura, filtros de contenido, límites de tarifas, monitoreo y equipo rojo.
- Precisión, parcialidad, robustez, deriva, explicabilidad, sistema de evaluación, umbral de aceptación, cambio de aviso y reevaluación.
- IP/licensing, privacy, security, incident, evidence, portability, export, deletion, and provider exit.
- Los servicios de IA todavía requieren inventario, propiedad, identidad, mínimo privilegio, gobernanza de datos, desarrollo seguro, registro, respuesta a incidentes, gestión de proveedores, resiliencia y eliminación verificada. | Respuesta

## 26. Open-Source Tools

- Herramientas de código abierto soportan inventario, postura, IaC, Kubernetes, tiempo de ejecución, secreto y encontrar evidencia.\*

### Tool\*\* Silencioso\*\*

|. | | Prowler | Seguridad en la nube postura y evaluación del cumplimiento Revisión de la configuración de seguridad de Multi-cloud tención Steampipe – SQL consultas y paneles a través de las API de la nube Nube Custodio de la Nube tención Checkov – Infraestructura como código y configuración escaneado tención Trivy | Imágenes, repositorios, dependencias, secretos, Kubernetes e IaC cheques – | tóxico tóxico Terraform análisis de seguridad estática | | Terrascan | Escaneo basado en políticas IaC | OpenTofu | Infraestructura de código abierto

como provisión | Política Abierta Agente Silencioso Decisiones generales de política como código | | Kyverno | confidencialidad kube-bench Comprobaciones de Benchmark – | kube-hunter | Kubernetes exposición descubrimiento Ø Falco | para la detección de seguridad en tiempo de ejecución nativa en la nube | Gitleaks | Detección secreta en fuente e historia | TruffleHog | Un descubrimiento secreto verificado a través de repositorios y almacenamiento | Wazuh fort Endpoint, burden, file-integrity, log, and alert monitoring | – DefectoDojo tóxico Encontrar la ingesta, la deduplicación, la remediación y la retesta

**TEN Autorización y seguridad en costos:** Utilice herramientas sólo en cuentas de nube aprobadas, inquilinos, clusters, repositorios, datos y redes. Comienza solo a leer o a correr seco. Protege las credenciales e informes. La remediación automatizada puede eliminar datos, interrumpir el servicio, crear costos o ampliar el acceso; requerir revisión, aprobación, devolución y registro. | |.

## 26.1 Prowler

Objetivo: Evaluación de la postura y el cumplimiento de la seguridad en la nube. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Usar un papel de laboratorio sólo lectura, elegir el proveedor y marco de la nube correctos, ejecutar una evaluación limitada, validar los hallazgos, corregirlos y repetir.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest. Eliminar las credenciales temporales y proteger la salida.

## 26.2 ScoutSuite

Propósito: Revisión de configuración de seguridad multicloud. Proyecto oficial: [Seguido](#)

Comenzar rápido seguro: Crear credenciales de laboratorio de menos privilegios, escanear sólo cuentas aprobadas, proteger el informe local, validar hallazgos y eliminar credenciales.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest. Eliminar las credenciales temporales y proteger la salida.

## 26.3 Steampipe

Propósito: SQL consultas y paneles a través de APIs de nube. Proyecto oficial: [Seguido](#)

Comenzar rápido seguro: Configurar un plugin de laboratorio con acceso sólo lectura, ejecutar una consulta de inventario estrecha, comparar resultados con la política, y guardar evidencia de búsqueda/versión.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest. Eliminar las credenciales temporales y proteger la salida.



## 26.4 Custodio de Nube

Objetivo: Gobernanza de la nube y automatización de políticas. Proyecto oficial: [Seguido](#)

Comenzar rápido seguro: Escribir una política de laboratorio en modo de gestión seca o reporte, seleccionar pruebas cuidadosamente, revisar entre pares, añadir puertas de aprobación, y permitir acciones sólo después de la autorización.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest.

Eliminar las credenciales temporales y proteger la salida.

## 26.5 Checkov

Propósito: Escaneo de configuración y código de infraestructura. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Escanear un repositorio de entrenamiento, revisar la política y el recurso exactos, validar falsos positivos, código correcto, excepciones de documentos, y rescane.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest.

Eliminar las credenciales temporales y proteger la salida.

## 26.6 Trivy

Propósito: Imágenes, repositorios, dependencias, secretos, Kubernetes y chequeos IaC. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Escanear un repositorio de entrenamiento autorizado o imagen, validar hallazgos, remediar o aprobar excepciones, y rescane en CI.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest.

Eliminar las credenciales temporales y proteger la salida.

## 26.7 tfsec

Propósito: Análisis de seguridad estática Terraform. Proyecto oficial: (<https://github.com/aquasecurity/tfsec>)

Comenzar rápido seguro: Correr contra una carpeta Terraform de laboratorio, inspeccionar la lógica de reglas y el contexto, corregir los ajustes inseguros, suprimir sólo con la racionalidad aprobada, y repetir.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest.

Eliminar las credenciales temporales y proteger la salida.

## 26.8 Terrascan

Objetivo: Análisis de IaC basado en políticas. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Escaneo aprobó ejemplos Terraform o Kubernetes, revisar políticas y severidad, corregir y retener los resultados antes y después.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest.

Eliminar las credenciales temporales y proteger la salida.

## 26.9 OpenTofu

Objetivo: Suministro de infraestructura de código abierto. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Use una cuenta de sandbox, pin proveedores/modules, revise el plan, requiera aprobación antes de aplicar, proteja el estado y secretos, y destruya los recursos de laboratorio.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest.

Eliminar las credenciales temporales y proteger la salida.

## 26.10 Agente de política abierta

Objetivo: Decisiones generales de política como código. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Escribir una pequeña política de laboratorio, probar casos de permiso y error, cambios de revisión por pares, decisiones de registro y preservar la autoridad de excepción humana.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest.

Eliminar las credenciales temporales y proteger la salida.

## 26.11 Kyverno

Objetivo: Gestión de políticas nativas de Kubernetes. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Aplicar una política de comprobación de cuentas en un grupo de laboratorio, revisar los recursos afectados, las excepciones de prueba, luego hacer cumplir sólo después de que la carga de trabajo esté lista.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest.

Eliminar las credenciales temporales y proteger la salida.

## 26.12 kube-bench

Propósito: Kubernetes CIS Comprobaciones de Benchmark. Proyecto oficial: [ejecutar] (<https://github.com/aquasecurity/kube-bench>)

Inicio rápido seguro: Ejecutar en un grupo de laboratorio autorizado, confirmar referencia/versión y responsabilidad de servicio gestionado, validar resultados, corregir y repetir.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest.  
Eliminar las credenciales temporales y proteger la salida.

### 26.13 kube-hunter

Propósito: descubrimiento de exposición de Kubernetes. Proyecto oficial: [ejecutar]  
(<https://github.com/aquasecurity/kube-hunter>)

Comienzo rápido seguro: Use sólo un grupo de laboratorio aislado con autorización escrita, comience con descubrimiento pasivo, valide la exposición, correcto y retest.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest.  
Eliminar las credenciales temporales y proteger la salida.

### 26.14 Falco

Propósito: Detección de seguridad de tiempo de ejecución nativa en la nube. Proyecto oficial: (<https://falco.org/>)

Inicio rápido seguro: Despliegue en un laboratorio, genere un evento de prueba inofensivo, confirme telemetría y alerta, sintonice con control de versiones y límites de cobertura de documentos.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest.  
Eliminar las credenciales temporales y proteger la salida.

### 26.15 Gitleaks

Propósito: Detección secreta en fuente e historia. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Escanear un repositorio de entrenamiento autorizado, verificar cada hallazgo, revocar secretos de prueba expuestos, eliminar con seguridad, añadir prevención y rescatar.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest.  
Eliminar las credenciales temporales y proteger la salida.

### 26.16 TruffleHog

Propósito: descubrimiento secreto verificado a través de repositorios y almacenamiento.  
Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Usar un repositorio de laboratorio sintético, proteger la salida, validar el comportamiento del detector, rotar las credenciales afectadas y limpiar documentos.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest.  
Eliminar las credenciales temporales y proteger la salida.

## 26.17 Wazuh

Objetivo: Punto final, volumen de trabajo, integridad de archivos, registro y vigilancia de alerta.  
Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Inscribir un volumen de trabajo de laboratorio, desencadenar un evento inofensivo, verificar la recogida y respuesta, cobertura de documentos y proteger los resultados.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest.  
Eliminar las credenciales temporales y proteger la salida.

## 26.18 DefectoDojo

Propósito: Encontrar ingesta, deduplicación, remediación y retest. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Importar resultados de laboratorio seguros, validar duplicados y severidad, asignar propietarios/fechas, adjuntar evidencia de corrección, y cerrar después de la prueba.

Retain: authority, account/region/scope, role/permissions, tool/version, policy/query, source data, date, population, result, analista validation, limitation, finding, action, and retest.  
Eliminar las credenciales temporales y proteger la salida.

## 27. Manual de seguridad en la nube para gerentes

*Los administradores mantienen la velocidad de la nube alineada con la propiedad, los obstáculos, la evidencia, la resiliencia y las decisiones de riesgo.*

**Area | Pregunta principal** | . | | Inventario | ¿Se reconcilian todas las cuentas, recursos, propietarios, datos y costos? | Inquilino o recurso público desconocido | ¿Se asignan y prueban cada proveedor/clómero/control compartido? Informe del Proveedor Permanente tratado como prueba de cliente | Identidad permanente ¿Son los permisos de administración y carga de trabajo menos, temporales, revisados y supervisados? – Claves estáticas o administración de pie | ¿Dónde están los datos sensibles, quién puede usarlo, y puede ser eliminado/exportado? – Replicaciones desconocidas, subprocesadores, o entrenamiento de IA | ¿Son consistentes las zonas de aterrizaje, las barreras, la tala, las redes, las claves y la recuperación? | Carga de trabajo bypass fundación compartida – Envío Silencioso ¿Ha protegido la procedencia el código, los artefactos, los oleoductos y los cambios? | Cambios de producción directa sin traza – Monitorización | ¿Las exposiciones y alertas crean investigación y corrección? | Dibujo verde con población incompleta ¿Puede el servicio completo cumplir los escenarios probados de RTO/RPO y falta de proveedores? – Respaldo existe pero restaurado no probado

## 27.1 Ritmo operativo

- Semanal: graves exposiciones, recursos públicos, cambios de privilegios, lagunas de registro, vulnerabilidades críticas, incidentes y anomalías de costos con impacto en la seguridad.
- Mensual: propiedad de cuenta/recurso, deriva, excepciones, asesorías de proveedores, edad clave/secreta, búsqueda de remediación y sombra SaaS/cloud.
- Trimestralmente: revisión de derechos, pruebas de recuperación, cambios de garantía de proveedores, concentración, residencia de datos, métricas y deuda técnica.
- En cada cambio importante de liberación/providente: arquitectura, responsabilidad, datos, amenaza, prueba, retroceso, evidencia y aceptación de riesgos.

### 28. Guía de la carrera de analista junior

*Los analistas de seguridad de la nube Junior crean valor a través de inventarios precisos, revisión de posturas, evidencia, remediación y comunicación.*

“Estilo medio/image10.png”=“Ancho:6.15in; Altura:3.39605in” alt=“Los laboratorios de seguridad y la evidencia trazable convierten los conceptos de la nube en prueba de cartera”.

Gráfico 10 Camino analista de seguridad de la nube junior

## 28.1 Funciones comunes

- Analista de Seguridad Junior Cloud
- Cloud GRC / Análisis de Cumplimiento
- Ingeniero de Seguridad de la Nube (asociado)
- DevSecOps Analyst
- Análisis de la gestión de posturas en la nube
- Analista IAM
- Análisis de la seguridad
- Análisis de la respuesta de incidentes en la nube

## 28.2 Típico trabajo

- Mantener inventarios de cuentas/recurso/propietario/datos y matrices de responsabilidad.
- Revise IAM, red, almacenamiento, registro, clave, copia de seguridad, SaaS y configuración del proveedor utilizando herramientas de sólo lectura.
- Scan IaC, imágenes, dependencias, Kubernetes y repositorios en procedimientos aprobados.

- Validar los hallazgos contra el contexto real; escribir un riesgo claro y corrección; pista de retest.
- Reunir SOC/ISO/CSA/provider evidencia y probar los controles/CUECs del cliente.
- Construir paneles con poblaciones definidas, fuentes, limitaciones, umbrales y acción.
- Apoyar los plazos de incidentes en la nube, preservación de evidencias, contención y recuperación.

## 29. Laboratorio Ficcional, Plan de Treinta Días y Preparación de Entrevistas

*Un ambiente de nube ficticia puede producir una cartera junior segura y creíble.*

La regla del laboratorio:\*\* Utilice una cuenta de sandbox con límites de gasto, datos sintéticos, cargas de trabajo de entrenamiento aisladas y autorización escrita. Nunca escanear objetivos públicos, empleadores, proveedores, o cuentas que no posee. Destruir los recursos del laboratorio y eliminar las credenciales después. — |. |

### 29.1 Portfolio lab

- Crear una compañía ficticia de 75 personas con una aplicación web de clientes, almacenamiento de objetos, base de datos gestionada, carga de trabajo de Kubernetes, SaaS CRM, proveedor de identidad y piloto de IA.
- Construir jerarquía de cuentas, estándar de propiedad/tag, flujo de datos, matriz de responsabilidad compartida, diagrama de zona de aterrizaje y registro de riesgos.
- Escribir IaC aprobado para una pequeña caja de arena usando OpenTofu; escanear con Checkov, Trivy, tfsec o Terrascan antes de aplicar.
- Configurar funciones de mínimo privilegio, MFA, registros centrales, almacenamiento privado, cifrado, secretos, controles de red, respaldo y límites de costes.
- Correr Prowler o ScoutSuite sólo lectura; validar cinco hallazgos; correcto y repetir.
- Utilizar kube-bench/Kyverno/Falco en un grupo de laboratorio y responsabilidad de documentos y limitaciones.
- Revise un proveedor sintético SOC/ISO/CSA conjunto de pruebas y escriba vacíos de control del cliente.
- Ejecute una tabla de incidentes de identidad de la nube y una prueba de restauración contra RTO/RPO ficticio.
- Publicar sólo evidencias sanitarias y etiquetar el proyecto ficticio, educativo y no una certificación del proveedor.

## 29.2 Plan de 30 días

### Días

---

TEN 1–3

4–6

7–9 Silencioso Identidad, red, datos, cripto tención Cuatro documentos de trabajo de control

TEN 10–12 ANTERIENTE ATENCIÓN, postura, vulnerabilidad

13–15

TEN 16–18

TEN 19–21

y respuesta a incidentes

TEN 25–27

28–30

## 29.3 ¿Qué es responsabilidad compartida?

El proveedor y el cliente dividen tareas de seguridad por modelo de servicio, función, contrato y configuración. El límite exacto debe ser documentado y probado.

## 29.4 IaaS versus PaaS versus SaaS?

IaaS le da al cliente más responsabilidad de la carga de trabajo; PaaS gestiona más tiempo de ejecución; SaaS gestiona la plataforma de aplicación mientras que el cliente todavía controla a los usuarios, configuraciones de arrendatarios, datos, integraciones y puntos finales.

## 29.5 ¿Por qué la identidad es crítica en la nube?

APIs y planos de control permiten que las identidades y fichas creen, cambien, accedan o eliminen recursos a escala.

## 29.6 ¿Qué es una zona de aterrizaje?

Una base de nube reutilizable para la jerarquía, la identidad, la creación de redes, la tala de registros, la vigilancia, los servicios compartidos y la separación del volumen de trabajo.

## 29.7 CSPM Scan versus valoración?

Un análisis detecta las condiciones configuradas. Una evaluación valida criterios, alcance completo, responsabilidad, fiabilidad de pruebas, proceso operativo, excepciones, riesgo y retest.

## 29.8 ¿Qué es la infraestructura como código?

Definiciones declarativas controladas por versiones de infraestructura que pueden ser revisadas, probadas, desplegadas y supervisadas para la deriva.

## 29.9 ¿Cómo aseguras secretos?

Utilice una tienda secreta gestionada, credenciales de corta duración, permisos estrechos, rotación, monitoreo y prevención en código, registros, imágenes y estado.

## 29.10 ¿Cómo verifica la recuperación de la nube?

Restaurar el servicio completo de fuentes protegidas, medir la pérdida de tiempo/datos real, validar la seguridad, datos, interfaces, rendimiento y aceptación empresarial.

## 29.11 ¿Qué es CSA CCM v4.1?

Un marco de control de la nube con 207 objetivos de control en 17 dominios, junto con CAIQ para asegurar el proveedor.

## 29.12 ¿Qué hace un buen analista junior?

Alcance cuidadoso, sólo lectura de primeros pasos, evidencia confiable, validación, escritura clara, manejo seguro de credenciales, y limitaciones honestas.

# 30. Plantillas, Glosario, Índice y Referencias

- Estructuras de trabajo reutilizables, términos clave, índice de sujeto y puntos de partida autorizados\*.

## 30.1 Registro de inventario y responsabilidad de la nube

|\*\* | |... | - Proveedor de la vida / arrendatario / cuenta / región infligida  
, Servicio de Vida / recurso / propietario  
“Pripose” / environment / criticality ·  
TENIENDO Datos / residencia / retención |  
Identidad permanente / privilegios / integración , la Red de Exhibiciones y la Exhibición |  
“La responsabilidad de los proveedores en la vida” “La responsabilidad de los clientes en la vida” Evidencia / evaluación de los resultados de la investigación La recuperación de la vida / el incidente / la salida de la vida

## 30.2 Papel de control de la nube

|\*\* | |... | Requirement / framework / version H  
“La vida escoge / la responsabilidad” La arquitectura de la vida y la aplicación han sido incomprensibles. IaC / policy / settings ·  
“Proceso permanente / propietario / frecuencia” Evidencia de la vida fuente / consulta / fecha Test / result / exceptions ·  
El riesgo / la causa / la protección provisional “Actuación permanente / propietario / fecha de vencimiento” Retest/Cierre de la vida



### 30.3 Revisión de la garantía de los proveedores

|\*\* | |... | “Proveedor/servicio/entidad en la vida” | Artifact/issuer/period |  
“Escopo/regiones/criterios” “Opinión/certificate status |  
Tests/excepciones/finamientos de la vida TENIDOS DE LAS CUESTIONES DEL cliente |  
“Las organizaciones de subservicio en la vida” Subsequent events/changes ·  
“Aplicabilidad/salidas de evidencia” “Actuación/decisión de riesgo”

### 30.4 Registro de incidentes y recuperación

|\*\* | |... | “Principio/comandante/severidad” Tenant/accounts/resources continuously  
Identidad/tokens / keys |  
“Datos/regiones/providentes” sobre la vida  
TENIENDO Timeline/logs/preservation |  
“Contenimiento/aprobaciones infligidas” Erradicación de la vida / fuente de confianza  
Restore / RTO / RPO |  
“Vidación/aceptancia de la vida” Lecciones/acción/retestigos sobre la vida

### 30.5 Glosario

|\*\* | |... | – Iniciativa de Evaluación de Consensos en la India | CCM Silencioso Cloud Controls Matrix. | TEN Cloud control plano TEN APIs y servicios utilizados para administrar recursos en la nube. | | CSPM Silencioso Manejo de posturas de seguridad en la nube. | tención Guardrail | Regla preventiva o detective que limita el uso de la nube. tención IaaS Silencioso infraestructura como servicio. TENCIÓN IaC | Infraestructura como código. | Zona de aterrizaje | Fundamentos de nube estándar para la gobernanza y la carga de trabajo. | PaaS Silencioso Plataforma como servicio. | tención Política como código | Reglas de política evaluadas a máquina almacenadas y gobernadas como código. | RPO | Pérdida máxima tolerable de datos medida en el tiempo. | RTO | Tiempo de restauración. – SaaS Silencioso Software como un Servicio. tención Servicio principal / carga de trabajo identidad | Identidad no humana utilizada por software o automatización. | | Responsabilidad compartida | Asignación de responsabilidades de proveedor y de seguridad de los clientes. TEN STAR | CSA Security, Trust, Assurance and Risk program/registry.

### 30.6 Subject index

Subjeto\*\* |... | – Servicios de inteligencia artificial Silencioso Aplicaciones / DevSecOps | 13  
Evaluación/evidencia en la vida cotidiana | CCM v4.1 | TENIDA Datos/privacy TENED 8, 21  
tención Encryption/keys/secrets tención 9 Identidad permanente | IaC / policy | 14 | Respuesta del incidente | | Inventario/zonas de aterrizaje | Silencioso Kubernetes Silenciosos en la vida Silencioso Silencioso | | . – Resiliencia/recuperación | | tención Serverless / APIs TEN 16 | | Responsabilidad compartida | Ø Herramientas para prevenir la muerte | Vulnerability | 11

### 30.7 Referencias oficiales

- Se indica que Controles de Nube Matrix v4.1
- (<https://cloudsecurityalliance.org/research/cloud-controls-matrix>)

- [\[ \]\(https://cloudsecurityalliance.org/star/resources\)](https://cloudsecurityalliance.org/star/resources)
- [Tecnología de nube](#)
- [Seguridad y privacidad de la nube pública](#)
- [Normativa de nube y recomendaciones](#)
- [ indica]NIST SP 800-210 — Control de acceso a la nube correspondiente](https://csrc.nist.gov/pubs/sp/800/210/final)
- [ ](https://csrc.nist.gov/projects/cloud-computing/publications)
- (https://www.cisa.gov/resources-tools/services/secure-cloud-business-applications-scuba-project)
- [ indica]CISA Cloud Security Technical Reference Architecture won/u contacto] (https://www.cisa.gov/resources-tools/resources/cloud-security-technical-reference-architecture)
- [Se indica](#)
- [Se indica] (https://www.cisa.gov/resources-tools/resources/zero-trust-maturity-model)
- [Seguridad de aplicaciones nativas en la nube de XOWASP Top 10 seleccionado/u fiel](#)

**Recordaje final:** Los proveedores, servicios, características, regiones, amenazas, estándares, contratos, precios, herramientas y recomendaciones de configuración cambian rápidamente. Verifique el proveedor actual y la fuente autorizada antes de la implementación, evaluación o aceptación del riesgo. |

|. |